

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(23)
MedHelp AB
Marieviksgatan 19
117 43 Stockholm

Decision following supervision according to the
Data Protection Regulation against
MedHelp AB

Contents

Decision of the Swedish Authority for Privacy Protection.....	2
Background.....	3
Reasoning of the decision.....	3
Legal background.....	3
National regulations on health and medical care.....	3
Data controller and data processor responsibilities.....	4
Fundamental principles and legal basis.....	4
Registered individuals' right to information.....	5
Security in connection with processing.....	5
MedHelp's data controller responsibilities.....	6
Responsibility for processing personal data of care seekers performed by MediCall...	6
MedHelp's information in the supervisory matter.....	6
MediCall's information in the incident report.....	7
IMY's assessment.....	7
Responsibility for the personal data incident in the storage server Voice NAS.....	10
Information from MedHelp, MediCall, and Voice in the incident reports.....	10
Information from Voice in the supervisory matter DI-2019-2488.....	11
MedHelp's information in the supervisory matter.....	11
IMY's assessment.....	12
Obligation to provide information to care seekers.....	15
IMY's assessment.....	15
Responsibility for backup.....	17
IMY's assessment.....	17
Choice of intervention.....	18

Diary number:
DI-2019-3375
Your diary number:

Date:
2021-06-07
Swedish Data Protection Authority
Diary Number: DI-2019-3375
2(23)
Date: 2021-06-07

Possible intervention measures.....	18
Administrative fine to be imposed.....	18

Determination of the amount of the administrative fine.....	19
General provisions.....	19
Administrative fine for each violation.....	20
Orders.....	22
How to appeal.....	23

Decision of the Swedish Data Protection Authority

As the data controller healthcare provider under Chapter 2, Section 6 of the Patient Data Act (2008:355), PDL, MedHelp AB (MedHelp) has processed personal data about patients seeking care in violation of the General Data Protection Regulation¹ in the following ways.

a)
MedHelp has, from May 25, 2018, to August 31, 2019, by disclosing personal data to the Thai company MediCall and allowing MediCall to collect personal data, processed personal data in violation of Articles 5.1 a, 6, and 9.1 of the General Data Protection Regulation.

b)
MedHelp has, from an unknown date until February 18, 2019, exposed personal data in audio files with recorded phone calls to 11772 over the internet without protection against unauthorized disclosure or unauthorized access to the personal data in the storage server Voice NAS. MedHelp has thereby, in violation of Articles 5.1 f and 32.1 of the General Data Protection Regulation, failed to take appropriate technical and organizational measures to ensure an adequate level of security for the data.

c)
At the time of the inspection on March 20, 2019, MedHelp, in addition to a voice response message stating that the call is being recorded for patient safety and quality purposes, did not inform patients seeking care about the company's processing of personal data in connection with the collection of personal data during phone calls to 1177. MedHelp has thereby processed personal data in violation of Articles 5.1 a and 13 of the General Data Protection Regulation.

d)
At the time of the inspection on March 20, 2019, MedHelp had not backed up audio files with recorded calls to 1177 that were answered by MedHelp's nurses within MedHelp's telephony platform. MedHelp has thereby processed personal data in violation of Articles 5.1 f and 32.1 of the General Data Protection Regulation.

The Swedish Data Protection Authority (IMY) decides, based on Articles 58.2 and 83 of the General Data Protection Regulation, that MedHelp shall pay an administrative fine of 12,000,000 (twelve million) kronor for the violations as follows. 3,000,000 (three

1 EUROPEAN PARLIAMENT AND COUNCIL REGULATION (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

2 The website 1177.se states, "Call the phone number 1177 for medical advice 24/7."

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

3(23)

Date: 2021-06-07

Millions) kronor refers to item a), 8,000,000 (eight million) kronor refers to item b), 500,000 (five hundred thousand) kronor refers to item c), and 500,000 (five hundred thousand) kronor refers to item d).

IMY orders, pursuant to Article 58.2 d of the Data Protection Regulation, MedHelp to promptly and no later than two months after the decision has become final, take the following actions.

1) Inform callers seeking care who call 1177 about MedHelp's processing of personal data in accordance with Article 13 of the Data Protection Regulation and Chapter 8, Section 6 of the PDL.

2) Regarding audio files with recorded calls to 1177, which are answered by MedHelp's nurses within MedHelp's telephony platform, perform backups with a defined periodicity and store the backups

securely, well separated from the original data in accordance with Chapter 3, Section 12 of HSLF-FS 2016:40, and decide how long the backups should be retained and how often recovery tests of the copies should be conducted in accordance with Chapter 3, Section 13 of HSLF-FS 2016:40.

Background

Computer Sweden published an article on February 18, 2019, titled "2.7 million recorded calls to 1177 Vårdguiden completely unprotected on the internet." The article states, among other things, that "On an open web server, completely without password protection or other security, we have found 2.7 million recorded calls to the advisory number 1177."

IMY initiated supervision of MedHelp and conducted an inspection at MedHelp on March 20, 2019, to verify how MedHelp processed personal data within the framework of 1177.

IMY also initiated supervision of Voice Integrate Nordic AB (Voice) and Inera AB. It was revealed that three regions employed MedHelp as a healthcare provider when callers seeking care dial 1177 for medical advice and Inera AB to connect the calls to MedHelp. Therefore, IMY initiated supervision of the Health and Medical Care Board of Region Stockholm, the Regional Board of Region Sörmland, and the Regional Board of Region Värmland.

Justification of the Decision

Legal Background

National Regulations on Health and Medical Care

The mission of health and medical care is regulated in, among other laws, the Health and Medical Care Act (2017:30), HSL.

Measures to medically prevent, investigate, and treat diseases and injuries are defined as health and medical care, Chapter 2, Section 1 of HSL. The principal authority refers to the region or municipality that, according to the law, is responsible for providing health and medical care to the population in the region or municipality. Within a principal authority's geographical area, one or more healthcare providers may operate, Chapter 2, Section 2 of HSL. A healthcare provider refers to a government authority, region, municipality, another legal entity, or individual entrepreneur conducting health and medical care activities, Chapter 2, Section 3 of HSL. Regions and municipalities may, while retaining principal authority, enter into agreements with others to perform the tasks for which the county council or municipality is responsible, Chapter 15, Section 1 of HSL. Those who have a statutory responsibility for providing care are referred to as the principal authority.

Integritetsskyddsmyndigheten

Diarienummer: DI-2019-3375

4(23)

Datum: 2021-06-07

The responsibility does not imply an obligation to conduct the operations oneself, but the operation can be carried out by someone else who is then referred to as the care provider (prop. 1981/82:97 p. 33 f.). The public responsibility as the principal does not entail decision-making authority over the care provider's daily operations, nor does it relieve the care provider of the responsibilities that come with the role of care provider (prop. 2016/17:43 p. 86).

Anyone who belongs to or has belonged to the healthcare personnel within the private healthcare sector is prohibited, according to Chapter 6, Sections 12–15 of the Patient Safety Act (2010:659), (PSL), from unlawfully disclosing what he or she has learned about an individual's health condition or other personal circumstances in the course of their work. The Public Sector's operations are governed by the Public Access to Information and Secrecy Act (2009:400) (OSL).

Data Controller and Data Processor

According to Article 4.7 of the General Data Protection Regulation (GDPR), a data controller is a natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data. If the purposes and means of processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be appointed may be prescribed in Union law or in the national law of the Member States.

According to Chapter 2, Section 6 of the Data Protection Act (PDL), a care provider is the data controller for the processing of personal data that the care provider carries out in connection with individual-oriented care in its operations, for example regarding the obligation to maintain patient records.

According to Article 24 of the GDPR, the data controller shall, taking into account the nature, scope, context, and purposes of the processing, as well as the risks, implement appropriate technical and organizational measures to ensure – and be able to demonstrate – that the processing is performed in accordance with the GDPR.

A data processor is defined, according to Article 4.8 of the GDPR, as a natural or legal person, public authority, agency, or other body that processes personal data on behalf of the data controller. The data processor may only process personal data on the instructions of the data controller, according to Article 29 of the GDPR.

Fundamental Principles and Legal Basis

Personal data shall, according to Article 5.1 a of the GDPR, be processed lawfully, fairly, and transparently in relation to the data subject (the principle of lawfulness, fairness, and transparency). According to Article 5.1 f, personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (the principle of integrity and confidentiality). Data controllers shall, according to Article 5.2, be responsible for and be able to demonstrate compliance with the principles in Article 5.1 (the principle of accountability).

For the processing of personal data to be lawful, it must be based on one of the legal grounds specified in Article 6.1 of the GDPR. In the context of processing for healthcare purposes, it is primarily Article 6.1 c (legal obligation) or 6.1 e (public interest or exercise of official authority) that may be applicable. According to Article 6.3, the basis for processing specified in Article 6.1 c and e must be established in accordance with Union law or the national law of a Member State that...

Swedish Data Protection Authority

Diary Number: DI-2019-3375

5(23)

Date: 2021-06-07

the data controller is subject to. This means that if a healthcare provider's processing of personal data is necessary to fulfill a legal obligation or to perform a task in the public interest, it is required for the processing to be lawful that the legal obligation or the task in the public interest is regulated by national law (or by Union law).

For activities under, among others, the Health and Medical Services Act (HSL), there are supplementary data protection provisions primarily in the Data Protection Act (PDL) and in HSLF-FS 2016:40, which among other things contain rules on information security and on the physical protection of information systems.

According to Chapter 1, Section 2 of the PDL, information management within healthcare must be organized so that it ensures patient safety and good quality and promotes cost-effectiveness. Personal data must be designed and otherwise processed so that the privacy of patients and other data subjects is respected. Documented personal data must be handled and stored so that unauthorized persons do not gain access to them.

Health information constitutes so-called sensitive personal data. It is prohibited to process such personal data according to Article 9.1 of the General Data Protection Regulation (GDPR), unless the processing falls under one of the exceptions in Article 9.2.

Rights of the data subject to information

The data controller's obligation to voluntarily provide data subjects with information about the processing of personal data is stated in Articles 13 and 14 of the GDPR. The information to be provided to data subjects is relatively extensive. In addition to what is stated in Articles 13 and 14, the

healthcare provider that is the data controller according to Chapter 2, Section 6 of the PDL must provide additional information according to Chapter 8, Section 6 of the PDL to the data subject. The information according to Chapter 8, Section 6 of the PDL must include, among other things, what applies regarding search terms, direct access, and disclosure of data on media for automated processing.

Security in connection with processing

According to Article 32.1 of the GDPR, both the data controller and the data processor must take appropriate technical and organizational measures to ensure a suitable level of security to protect the data being processed. In assessing what technical and organizational measures are appropriate, the data controller and the data processor must consider the latest developments, the implementation costs, and the nature, scope, context, and purposes of the processing as well as the risks to the rights and freedoms of natural persons. According to Article 32.1, appropriate protective measures, where appropriate, include a) pseudonymization and encryption of personal data, b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing. According to Article 32.2 of the GDPR, in assessing the appropriate level of security, special consideration must be given to the risks posed by the processing, in particular the risks of accidental or unlawful destruction, loss, or alteration, or unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed.

Integrity Protection Authority

Diary Number: DI-2019-3375

6(23)

Date: 2021-06-07

The National Board of Health and Welfare has, in HSLF-FS 2016:40, based on § 3 of the Patient Data Regulation (2008:360) and after consultation with IMY, issued regulations necessary for the implementation of the PDL regarding security measures in fully or partially automated processing of personal data. A data controller healthcare provider must, according to Chapter 3, § 12 of HSLF-FS 2016:40, ensure that personal data processed in information systems is backed up with a defined periodicity and that the backups are stored securely, well separated from the original data. The regulation thus specifies in Chapter 3, § 12 a security measure to be taken by data controllers. The healthcare provider must, according to Chapter 3, § 13, decide how long the backups should be retained and how often recovery tests of the copies should be conducted.

MedHelp's Data Controller Responsibility

From MedHelp's report of a personal data incident on February 20, 2019 (IMY's case PUI-2019-689), it appears that MedHelp claims to be the data controller concerning the processing of sensitive personal data in the form of audio files that have been exposed to the internet without any protective mechanisms.

In this supervisory matter, MedHelp states that the company is a healthcare provider according to the definition in Chapter 1, § 3 of the PDL and thus a data controller according to Chapter 2, § 6 of the same law for the personal data that the company processes when individuals call 1177. The company further states that, as a complement to the journal notes, the calls are saved by being recorded and stored. These recordings are part of the care documentation. MedHelp considers itself to be the data controller for the files stored on the server at Voice on behalf of MediCall. When the calls could no longer be stored at Voice, they were transferred to MedHelp's servers.

IMY shares MedHelp's view that MedHelp is a data controller healthcare provider according to Chapter 2, § 6 PDL and that MedHelp, for the individual-oriented care that occurs when individuals call 1177, may process personal data for purposes related to care documentation, for example, through the recording of calls to 1177.

Responsibility for the Processing of Personal Data of Patients Seeking Care as Performed by MediCall

MedHelp's Information in the Supervisory Matter

Regarding MediCall's role in healthcare advice via telephone, MedHelp has stated the following, among other things.

MedHelp has engaged MediCall as a subcontractor for healthcare advice via telephone when individuals call 1177. MediCall is a Thai company operating in Thailand. MedHelp receives approximately 3 million calls per year within the framework of 1177. 20 percent of the traffic goes to MediCall and the rest to MedHelp. All nurses have Swedish nursing licenses and meet the requirements in the agreements with the regions. The nurses working for MediCall are employed by MediCall. Nurses at both MedHelp and MediCall take notes in MedHelp's journal system, Princess, and there is recording of the telephone calls to 1177.

MedHelp is the responsible healthcare provider. The healthcare provider and the patient are located in Sweden when care is provided. MediCall is subject to documentation obligations. To record the calls, a balancing of interests is used as the legal basis.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

7(23)

Date: 2021-06-07

MedHelp entered into an agreement with MediCall on October 15, 2012, regarding healthcare advice, and in connection with this, a personal data processing agreement was concluded. The parties entered into an addendum on October 1, 2016, and a new agreement titled "Agreement regarding telephone healthcare advisory services." An addendum to this agreement was established and signed on March 1-2, 2019. Appendix 4 to the addendum also contains a new personal data processing agreement that replaces the previous personal data processing agreement from 2012. MedHelp has stated that the agreement and the personal data processing agreement will terminate on August 31, 2019, at which point MediCall's processing of personal data related to 1177 will also cease.

MediCall's information in the incident report

After IMY posed questions to MediCall, MediCall supplemented its report of the personal data incident on June 19, 2019, stating among other things the following. MediCall is a Thai company that provides advice via telephone and other communication channels in accordance with MedHelp's standards and procedures on behalf of MedHelp. The operations are conducted solely in Thailand. Personal data is made available to the on-duty nurse via MedHelp's journal system on a screen. The nurse responds and sees information based on what the caller has entered. After the call or during the call, a journal is maintained. When the call has ended, the journal is closed and cannot be reopened by the nurse. The call is stored in MedHelp's system immediately. MediCall thus sees the journal in MedHelp's system, works in the system, and documents in MedHelp's system; no information is saved by MediCall. The IT system is called Collab. When the incident occurred, calls came in via Biz, which handles incoming and outgoing calls. The calls were recorded by Biz and stored by Voice on behalf of MedHelp.

MediCall has a clause in its agreement dated September 2, 2012, with MedHelp that stipulates that the processing of personal data shall be conducted in accordance with applicable law. A new personal data processing agreement, including a confidentiality agreement, was signed on March 1, 2019.

MediCall has designated Voice as a personal data processor but is somewhat uncertain about this matter as MediCall sees them as a supplier directly to MedHelp. No personal data processing agreement has been signed between MediCall and Voice.

On August 29, 2019, MediCall voluntarily submitted a document to IMY as a supplement to its report of the personal data incident. At the top of the document, dated October 30, 2012, it states the Health and Medical Care Administration, Stockholm County Council, diary number HSN 0805-0652, and the subject "Regarding the request for approval of subcontractor." Under the heading "Describe how you ensure that the agreement is fulfilled with the help of the subcontractor regarding the points," it is stated among other things that MedHelp does this to improve staffing during on-call hours, which will provide higher availability for telephone healthcare advice to Vårdguiden (point 3). In point 5, it is stated that all services performed by MediCall will follow MedHelp's quality management system.

IMY's assessment

Swedish healthcare is subject to extensive regulation. In addition to the provisions of the General Data Protection Regulation, the Health and Medical Services Act (HSL) is of central importance. The law contains provisions on how Swedish healthcare operations should be organized and conducted.

Measures for the medical prevention, investigation, and treatment of diseases and injuries are defined as healthcare, Chapter 2, Section 1 of HSL. The term "principal" refers to the region or municipality that, according to the law, is responsible for providing healthcare to the population in the region or municipality. Within a principal's geographical area, one or more healthcare providers may operate, Chapter 2, Section 2 of HSL. The term "healthcare provider" refers to...

****Swedish Authority for Privacy Protection****

****Diary Number:** DI-2019-3375**

****Page:** 8(23)**

****Date:** 2021-06-07**

State authority, region, municipality, other legal entity, or individual entrepreneur engaged in health and medical care activities, Chapter 2, Section 3 of the Health and Medical Services Act (HSL).

Regions and municipalities may, while retaining principal responsibility, enter into agreements with others

to perform the tasks for which the county council or municipality is responsible, Chapter 15, Section 1 of HSL. The entity that has a statutory responsibility for providing care is referred to as the principal.

This responsibility does not imply an obligation to personally conduct the operations; rather, the operation may be carried out by another party, who is then referred to as the care provider (Prop. 1981/82:97, p.

33 f.). The public responsibility as the principal does not confer authority over the daily operations of the care provider,

nor does it relieve the care provider of the responsibilities that accompany the role of care provider (Prop. 2016/17:43, p. 86).

MedHelp is the data controller care provider for the processing of personal data that occurs in connection with the medical advice that MedHelp has been commissioned by the regions to perform. This means that MedHelp, according to Article 5.2 of the General Data Protection Regulation (GDPR), must be able to demonstrate that personal data is processed in a manner that complies with the principles in Article 5.1.

For the processing of personal data to be lawful, it must be supported by one of the legal bases specified in Article 6.1 of the GDPR. In the context of health and medical care, it is primarily Article 6.1 c (legal obligation) or 6.1 e (public interest or exercise of official authority) that may be

applicable. According to Article 6.3, the basis for processing specified in Article 6.1 c and e must be established in accordance with Union law or the national law of a member state to which the data controller is subject.

This means that if a care provider's processing of personal data is necessary to fulfill a legal obligation or

perform a task in the public interest, it is required for the processing to be lawful that the legal obligation or the task in the public interest is regulated by national law (or by Union law).

Within health and medical care, the GDPR is supplemented by the Patient Data Act (PDL), which contains provisions regarding, among other things, who is the data controller, the obligation to maintain patient records, and the permitted purposes for processing personal data. According to Chapter 1, Section 3 of the PDL,

the scope of application of the PDL includes activities referred to in, among other things, the Health and Medical Services Act (2017:30), HSL.

The determination in Chapter 2, Section 6 of the PDL that the care provider is the data controller is a national specification of Article 4.7 of the GDPR.

A care provider needs to process data about health and sometimes also other special categories of personal data according to Article 9.1 of the GDPR, known as sensitive personal data. As a general rule, it is prohibited to process sensitive personal data according to the same article. The exceptions to the prohibition are outlined in Article 9.2. For health and medical care, there is an exception in Article 9.2 h that is applicable provided that there is a legally regulated duty of confidentiality according to Article 9.3.

For Swedish health and medical care, it is primarily the regulations in HSL and PDL as well as the duty of confidentiality in the Public Access to Information and Secrecy Act (OSL) and in Chapter 6, Sections 12-15 of the Patient Safety Act (PSL) that provide the legal basis for the processing of personal data to be lawful in the manner intended in Articles 6.1 e, 6.2 and 6.3 as well as 9.2 h and 9.3 of the GDPR (Prop. 2017/18:105, pp. 58 and 94 and Prop. 2017/18:171, p. 105).

Through both MedHelp's and MediCall's information, it has been revealed that both MedHelp and MediCall have taken measures that fall under the concept of health and Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

9(23)

Date: 2021-06-07

Healthcare according to the definition in Chapter 2, Section 1 of the HSL concerning 1177 through its measures to medically prevent, investigate, and treat diseases and injuries. The relationship is regulated through agreements and data processing agreements. MediCall has processed personal data in order to provide healthcare. This has occurred by MediCall accessing personal data concerning patients on a computer screen via MedHelp's journal system and by responding to calls to 1177. During the conversation, MediCall collected personal data by entering care documentation into MedHelp's journal system, which also constituted processing of personal data.

However, MediCall is a Thai company operating in Thailand. This means that the Swedish regulations in the area of healthcare do not apply, even though the nurses working at MediCall have Swedish licenses. MediCall has therefore not been imposed national duties and responsibilities under the provisions of the HSL and is not a healthcare provider under Swedish law. Consequently, MediCall is also not covered by the scope of application of the PDL according to Chapter 1, Section 3 of the PDL, which states that the PDL applies to the processing of personal data by healthcare providers within the healthcare sector. This further implies that MediCall cannot be subject to the documentation obligation according to Chapter 3 of the PDL, as MedHelp has stated.

The duty of confidentiality for private healthcare providers is regulated in Chapter 6, Sections 12–15 of the PSL. It is stated, as a main rule, that those who belong to or have belonged to healthcare personnel within private healthcare may not unlawfully disclose what they have learned about an individual's health condition or other personal circumstances in their activities. According to Chapter 1, Section 2 of the PSL, healthcare refers to activities covered by the HSL or other national regulations in the healthcare area, such as the Dental Care Act, the Act on Insurance Medical Investigations, etc. The activities of MediCall are not covered by the national provisions either in the HSL or in any of the other specified statutes, which means that Chapter 6 of the PSL is also not applicable. MediCall therefore lacks a confidentiality obligation regulated by Swedish law.

The provisions in Chapter 6 of the PDL regarding consolidated record-keeping and in Chapter 25, Section 11, Paragraph 3 of the OSL mean that two or more Swedish healthcare providers can initiate a voluntary collaboration for healthcare purposes by following the provisions in Chapter 6 of the PDL (cf.

Prop. 2007/08:126 p. 132 f regarding that private healthcare can seek guidance for assessments of confidentiality in secrecy provisions). If MediCall had been a Swedish healthcare provider – i.e., covered by the HSL, PSL, and PDL – MedHelp and MediCall could have initiated a voluntary collaboration for healthcare purposes by following the provisions in Chapter 6 of the PDL regarding consolidated record-keeping.

MedHelp is a healthcare provider, and the legal basis for the processing of the personal data in question here is legal obligation or public interest according to Article 6.1 c or e of the General Data Protection Regulation, as established in Swedish law in statutes such as the PDL and HSL in accordance with Article 6.3 of the General Data Protection Regulation. Legal support for processing sensitive personal data despite the prohibition in Article 9.1 is found in Article 9.2 h and 9.3. Balancing of interests according to Article 6.1 f of the General Data Protection Regulation is not an applicable legal basis in this context.

By engaging MediCall as a subcontractor for healthcare advice via telephone when individuals call 1177, MedHelp has conducted healthcare and has thereby allowed MediCall to process personal data without legal support in Swedish law and without a legally regulated confidentiality obligation in the manner required by Article 9.3 of the General Data Protection Regulation.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

Page: 10(23)

Date: 2021-06-07

MedHelp entered into an agreement with MediCall on October 15, 2012, regarding "Medical Advice," and in connection with this, a data processing agreement was concluded. The parties entered into an addendum on October 1, 2016, and a new agreement titled "Agreement regarding telephone medical advice services." An addendum to this agreement was drafted and signed on March 1-2, 2019. In Appendix 4 to the addendum, there is also a new data processing agreement that replaces the previous data processing agreement from 2012.

The fact that Swedish regulations regarding health and medical care do not apply to a Thai company cannot be replaced by a data processing agreement or any other contractual arrangement. A data processor refers to a natural or legal person, public authority, institution, or other body that processes personal data on behalf of the data controller, as defined in Article 4.8 of the General Data Protection Regulation (GDPR). MediCall provides care and cannot constitute a data processor in this context, as a healthcare provider must have an independent basis for processing personal data, which MediCall lacks.

IMY states that MedHelp, as the data controller healthcare provider according to Chapter 2, Section 6 of the Data Protection Act (PDL), at least from May 25, 2018, to August 31, 2019, in connection with patients calling 1177 for medical advice, disclosed personal data both on a data screen and via telephone to MediCall and allowed MediCall to collect personal data for MedHelp's medical documentation, despite the fact that MediCall is not covered by the Health and Medical Services Act (HSL) and thus is not subject to the provisions of the Patient Safety Act (PSL) and the PDL. These processing activities have lacked legal support under Swedish law in the manner required by Article 6.3 and have been carried out without a legally regulated duty of confidentiality as required by Article 9.3 of the GDPR. Thus, the processing has lacked a legal basis according to Article 6 and has been conducted in violation of the prohibition on processing sensitive personal data in Article 9.1 of the GDPR. Consequently, the processing has also occurred in violation of the principle of legality in Article 5.1 a of the GDPR.

Responsibility for the personal data incident in the storage server Voice NAS

Information from MedHelp, MediCall, and Voice in the incident reports

In MedHelp's report of the personal data incident, the incident is described as sensitive personal data being exposed to the internet without any protective mechanisms and that an unknown number of audio files were accessible. The incident concerns patients and employees of the data controller's

subcontractor. The personal data involved in the incident is stated to include health, sexual life, personal identification numbers, dates of birth, identifying information, such as first and last names, and contact information. Furthermore, it is noted that MedHelp became aware of the personal data incident from the Deputy CEO of Inera AB.

IMY received MediCall's report of a personal data incident on February 21, 2019 (IMY's case PUI-2019-698). The incident is described as "Breach in subcontractor's (Voice Integrate Nordic AB) server." The incident concerns patients. The personal data involved in the incident is stated to include health, personal identification numbers, and identifying information, such as first and last names. After IMY posed questions to MediCall, MediCall stated on June 19, 2019, among other things, that the calls were stored at Voice on behalf of MedHelp.

IMY received Voice's report of a personal data incident on February 21, 2019 (IMY's case PUI-2019-705). The incident is described as a security hole in a storage server discovered by Computer Sweden, which published this information in an article.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

11(23)

Date: 2021-06-07

The incident concerns patients and business users to a lesser extent. Personal data involved in the incident is reported to include health information, personal identification numbers, identifying information such as first and last names, and contact information.

Information from Voice in the supervisory matter DI-2019-2488

Voice has reported the following, among other things.

Voice shut down the storage server on February 18, 2019, and changed it so that the server was no longer accessible via the internet by implementing ip-tables (a firewall tool to allow or block access opportunities in networks) directly on the server. After the incident was noted, MedHelp requested that IT forensics investigate the storage server Voice NAS. MedHelp was therefore granted access to Voice NAS on February 20, 2019. MedHelp is also reported to have started transferring the contents of Voice NAS to MedHelp's own servers. Whether the transfer of data occurred solely through copying the files or whether the files were deleted in connection with the copying was unknown to Voice. Voice stated in response to IMY's inquiry on March 14, 2019, regarding whether there were any call files left on Voice NAS, that the calls had been deleted at MedHelp's request on March 7, 2019.

Voice and MedHelp entered into a "Delivery Agreement – Services" signed on September 1, 2012. According to the agreement, Voice and MedHelp have had a close collaboration for many years in technology, security, and possible improvements in both technology, services, and production. The agreement describes services such as "Recording (within system) CC-50," "Call Recording," "Search functions for retrieval," and "Filtering or deletion of recordings at the customer's request." The delivery agreement is valid from 2012-09-01 to 2019-06-30.

As of February 18, 2019, there were 2.7 million files on the storage server Voice NAS; these files do not correspond to 2.7 million calls, but one call corresponds to an average of about three to four files, and one call can consist of up to ten files. A call flow occurs when a person calls 1177. The recorded calls are calls from individuals who have called the 1177 healthcare advice line and are then forwarded to MedHelp and MediCall.

Voice's assignment under the agreement with MedHelp and MediCall has been to deliver calls via its exchanges and provide support for functions and software covered by the agreement. Voice has developed the software Biz. It is correct that data files with recorded calls have been transferred from MedHelp to Voice NAS, a network-attached storage device. This was necessitated by MedHelp's own server crashing. MedHelp's server problems began as early as 2013, escalating and leading to an acute situation in the fall of 2015. Voice management did not participate in this decision or implement it but became aware that the files were there on February 18, 2019, when the incident was highlighted in the media.

No recordings should have been stored at Voice. A month before the General Data Protection Regulation was to come into effect, MedHelp suddenly sent over a data processing agreement. Such an agreement had not previously existed between the parties. The agreement was presented as a standard agreement that all contracting parties needed to enter into before the General Data Protection Regulation came into effect.

MedHelp's information in the supervisory matter

MedHelp has reported the following, among other things, in this supervisory matter.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

12(23)

Date: 2021-06-07

MedHelp was aware that MediCall stored calls with Voice, but MedHelp was not aware that the server had been made accessible without protective mechanisms from the internet. MediCall's nurses were connected to MedHelp's network from February 23, 2019, instead of to the telephony solution Biz at Voice. This meant that the incoming calls were redirected to MedHelp's servers and infrastructure, including Collab, which is a telephony solution that MedHelp operates itself.

MedHelp receives approximately 3 million calls per year within the framework of 1177. Eighty percent of these are handled by MedHelp and twenty percent are handled by MediCall, which previously used the IT solution Biz that includes audio file storage. Voice had built a web application that allows users to listen to the audio files. MedHelp has used the application for call follow-up. In order to access recordings, MedHelp's staff had to be logged into MedHelp's internal environment and additionally authenticate themselves in the web application. For reasons unknown to MedHelp, the stored content subsequently appeared on the internet. As the calls could no longer be stored with Voice, they were transferred to MedHelp's servers. MedHelp's storage devices have never crashed. MedHelp did not have any server problems that led to an acute situation in the fall of 2015. There has never been any transfer of data files containing recorded patient calls from MedHelp to Voice. MedHelp has at all times stored recordings of patient calls exclusively in-house on its own storage devices. Voice has never stored recordings on behalf of MedHelp. However, Voice has stored recordings of patient calls on behalf of MedHelp's subcontractor MediCall.

An agreement titled "Data Processing Agreement" was signed by MedHelp on May 7, 2018, and by Voice on May 10, 2018. Voice is referred to as the supplier in the agreement, which states, among other things, the following. MedHelp has entered into agreements with customers and partners, for example regarding an agreement for MedHelp to provide healthcare advice to customers and partners. The agreement regulates the MedHelp group's transfer of personal data to the supplier in connection with service agreements and other agreements made between MedHelp and the supplier. From section 11, it is clear that MedHelp has the right, after reasonable notice and in an appropriate manner, to allow itself and/or its representative to inspect that the supplier's processing of personal data is in accordance with the service agreement and that the supplier has taken appropriate security measures to protect the personal data processed on behalf of the MedHelp group. Furthermore, it is stated that the party shall continuously during the contract period conduct checks to ensure that the information security work is in accordance with applicable laws and regulations, which includes conducting internal audits, protective measures, and risk analyses.

IMY's Assessment

The audio files in the storage server Voice NAS at Voice contained recorded calls to 1177 that were answered by nurses at MediCall. As noted above, MedHelp, as the healthcare provider, is the data controller for these personal data. The data controller's responsibility includes ensuring that personal data is processed in accordance with applicable data protection regulations. This is evident from the fundamental principles in Article 5 and Article 24. It also includes, according to Article 5.2, the obligation to demonstrate compliance.

That MedHelp has allowed MediCall and Voice to process personal data through agreements does not affect the extent of MedHelp's responsibility. It is the data controller who has the ultimate responsibility

for the correct and lawful processing of personal data. MedHelp is also responsible for the security in connection with the processing.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

13(23)

Date: 2021-06-07

As previously noted, this concerns personal data documented in connection with healthcare advice when individuals seeking care called 1177 in the regions of Stockholm, Sörmland, and Värmland. It pertains to an operation for which MedHelp is the healthcare provider and thus the data controller. MedHelp must therefore, as the data controller, take appropriate technical and organizational measures to ensure a security level that is adequate in relation to the risk. In assessing the appropriate security level, special consideration must be given to the risks posed by the processing, particularly from accidental or unlawful destruction, loss, or alteration, or to unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed, as stated in Article 32.1 and 2 of the General Data Protection Regulation (GDPR). Ensuring an appropriate level of security means that the security level must be adapted to the risks associated with the specific processing.

The processing by MedHelp concerned 20 percent of the approximately 3 million phone calls that MedHelp received annually via 1177, totaling about 600,000 calls per year. Voice states in the supervisory matter DI-2019-2488 that as of February 18, 2019, there were 2.7 million files on the storage server Voice NAS, that these files do not correspond to 2.7 million calls, but that one call corresponds on average to about three to four files and that one call can consist of up to ten files. IMY estimates, based on the average, the number of stored calls in Voice NAS to be between 650,000 and 900,000. In other words, this concerns a very large number of calls.

Regarding the nature of the calls, it can be noted that they relate to healthcare advice and that health data is central. Health data constitutes sensitive personal data according to Article 9 of the GDPR and imposes high demands on the security of the data. Processing of personal data within healthcare generally entails a high risk to the rights and freedoms of the data subjects.

Care must particularly be based on respect for the patient's autonomy and privacy, as stated in Chapter 5, Section 1, Subsection 3 of the Health and Medical Services Act (HSL). Personal data must be designed and otherwise processed in such a way that the privacy of patients and other data subjects is respected, and documented personal data must be handled and stored so that unauthorized persons do not gain access to them, as indicated in Articles 5.1(f) and 32 of the GDPR, as well as in Chapter 1, Section 2, Subsections 2 and 3 of the Data Protection Act (PDL). There are also specific regulations in HSLF-FS 2016:40 regarding how personal data about patients should be protected.

Everyone who is ill has the right to access care. Individuals seeking care who call 1177 can be considered to have a high expectation that unauthorized persons will not be able to access information conveyed in a call, as patients have the right to a confidential and trusting relationship with healthcare providers. For private healthcare providers, confidentiality obligations are regulated in Chapter 6, Sections 12–15 of the Patient Safety Act (PSL), which healthcare personnel at a private provider must follow.

According to Article 32.1 of the GDPR, the data controller must take appropriate technical and organizational measures to ensure a security level that is adequate in relation to the risk for the protection of the data being processed. According to Article 32.2, in assessing the appropriate security level, special consideration must be given to the risks posed by the processing, particularly from accidental or unlawful destruction, loss, or alteration, or to unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

14(23)

Date: 2021-06-07

The ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services is, according to Article 32.1 b of the General Data Protection Regulation (GDPR), a measure that may be appropriate in relation to ensuring a security level that is suitable in relation to the risk. Another measure that may be appropriate in relation to ensuring a security level that is suitable in relation to the risk is, according to Article 32.1 d of the GDPR, a procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures that are to ensure the security of processing.

In light of the sensitive nature of the personal data, that the personal data was collected in a confidential context related to healthcare advice, the scope of the processing, and the high risks of the processing, IMY believes that there are, in summary, high demands for taking extensive security measures according to Article 32.1 of the GDPR. MedHelp's responsibility also includes the storage of personal data about patients that has occurred in Voice NAS.

IMY notes that a large number of calls to 1177 stored in Voice NAS were exposed to the internet without protection for an unknown period until February 18, 2019, when Voice took measures to prevent exposure to the internet. An exposure of personal data to the internet without protection meant that the personal data was accessible to anyone with an internet connection. This posed a high risk of unauthorized disclosure of or unauthorized access to the personal data.

MedHelp has stated that it was not aware that the personal data in Voice NAS had become accessible without protective mechanisms, that the stored content was made available online for unknown reasons to MedHelp, and that MedHelp became aware of the personal data incident from the Deputy CEO of Inera AB. IMY notes that MedHelp acted only after the incident by investigating Voice NAS, transferring the medical documentation to its own servers, and instructing Voice to delete the calls, which Voice carried out on March 7, 2019.

In this context, IMY concludes that MedHelp has lacked sufficient ability to continuously ensure confidentiality, integrity, availability, and resilience of the processing systems and services. According to IMY, MedHelp has also lacked an effective procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures that are to ensure the security of processing.

IMY notes that this concerns many personal data, which are both sensitive and subject to confidentiality, and that they have been exposed to the internet without protection, which has meant that they were accessible to anyone with an internet connection. MedHelp has thus not protected the personal data against unauthorized disclosure or unauthorized access and has therefore not complied with its obligation as a data controller to take appropriate technical and organizational measures that ensure a security level that is suitable in relation to the risk in accordance with Article 32.1 of the GDPR.

According to the fundamental security principle in Article 5.1 f of the GDPR, personal data must be processed in a manner that ensures appropriate security for the personal data, including protection against unauthorized or unlawful processing and against loss, destruction, or damage due to accidental events, using appropriate technical or organizational measures. The fact that personal data has been exposed to the internet without protection against unauthorized disclosure or unauthorized access means, according to IMY, that...

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

15(23)

Date: 2021-06-07

the security breach has been of such a serious nature that it also constitutes a violation of Article 5.1(f) of the General Data Protection Regulation.

Obligation to Provide Information to Patients

IMY has on June 25, 2019, reviewed a printout from www.1177.se regarding 1177 healthcare advice by phone. The website indicates that behind 1177 Vårdguiden stands the Swedish healthcare system through collaboration among all regions. 1177 is a national telephone number for healthcare advice that can be called around the clock. Each region operates its own healthcare advice service either in-house or through contracted subcontractors. The calls that are advisory calls are documented. The question "Who is responsible for ensuring that personal data is handled correctly?" is answered as follows: "It is your healthcare provider who is responsible for ensuring that personal data is handled in a correct and lawful manner. When care is provided by a region, it is one or more boards in the region that are ultimately responsible. In private healthcare, it is the company or the entity that conducts the care that is responsible."

MedHelp stated among other things during the inspection on March 20, 2019. MedHelp receives approximately 3 million calls per year within the framework of 1177. The information about personal data processing that should be provided and by whom is regulated in the agreement with the Health and Medical Care Administration, HSF (Region Stockholm, IMY's note), which is responsible for informing those who call the healthcare advice line 1177. A few weeks ago, no information was provided, but now some information is given. MedHelp does not have available what information is provided in the voice response. MedHelp cannot practically provide information in the voice response since it is HSF that controls it. MedHelp represents HSF and the brand 1177, so MedHelp cannot tell a person that they have reached MedHelp. MedHelp provides information on its website that MedHelp processes personal data. On April 25, 2019, MedHelp states that for Region Stockholm, the caller is informed that the call will be recorded for patient safety and quality purposes, that the agreement with Region Stockholm constitutes a publicly procured agreement where the contractual terms have thus been established by the region, and that as a service provider to the region, it is not possible for MedHelp to determine what information to be provided to the data subjects.

IMY's Assessment

The data controller shall, according to Article 12.1 of the General Data Protection Regulation, take appropriate measures to provide the data subject with all information according to Articles 13 and 14 in a concise, clear, and transparent, understandable, and easily accessible form, using clear and plain language, particularly for information specifically addressed to children. Article 13 specifies what information the data controller must provide when personal data is collected from the data subject. The data controller must, according to Article 13.1, provide information about, among other things, the identity and contact details of the data controller, contact details for the data protection officer where applicable, the purposes of the processing for which the personal data are intended, and the legal basis for the processing. The data controller must also, according to Article 13.1(f), provide specific information if they intend to transfer personal data to a third country.

Article 14 of the General Data Protection Regulation specifies what information the data controller must provide when personal data is not collected from the data subject. In applicable cases, information about whether the data controller intends to transfer personal data to a third country or an international organization and whether a decision by the Commission on adequate protection level exists or is absent, or, regarding the transfers referred to in Articles 46, 47, or Article 49.1 second paragraph, reference to appropriate or suitable safeguards and how a copy of them can be obtained or where they have been made available.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

16(23)

Date: 2021-06-07

The obligation to provide information is extensive and a fundamental prerequisite for individuals to gain knowledge about and control over how their personal data is processed. The requirement for transparency is a fundamental principle according to Article 5.1 a of the General Data Protection Regulation (GDPR). Recital 60 of the GDPR states that the principles of fair and transparent

processing require that the data subject is informed that processing is taking place and the purpose of it. The data controller should provide the data subject with all additional information necessary to ensure fair and transparent processing, taking into account the specific circumstances and context of the data processing.

Information must be provided according to Article 13.2, including that there is a right to request access to personal data from the data controller. A healthcare provider must also comply with Chapter 8, Section 6 of the PDL, which specifies what information the healthcare provider must provide to the data subject beyond what is stated in Articles 13 and 14. This information must include, among other things, what applies regarding search terms, direct access, and the disclosure of data on media for automated processing.

IMY notes that the public responsibility of Region Stockholm as the principal under the HSL does not imply any decision-making authority over MedHelp's daily operations, nor does it relieve MedHelp of the responsibilities that come with the role of healthcare provider and data controller. The accountability obligation in Article 5.2 of the GDPR means that it is MedHelp that is responsible for and must be able to demonstrate that MedHelp complies with the fundamental data protection principles in Article 5.1. Thus, it is MedHelp that has the ultimate responsibility for ensuring that the principle of transparency is followed by providing those seeking care with the necessary information about the processing of personal data.

When a person seeking care calls 1177, MedHelp, as the data controller healthcare provider, collects personal data for purposes related to care documentation. IMY finds that there are extensive requirements for information under Article 13 of the GDPR and Chapter 8, Section 6 of the PDL that MedHelp does not provide. It is not sufficient for MedHelp to inform those seeking care in a voicemail message that the call will be recorded for patient safety and quality purposes. For example, there is a complete lack of information that MedHelp is the data controller, about MedHelp's contact details, that personal data is collected for purposes related to care documentation, about the legal basis for the processing, and that there is a right to request access to personal data from the data controller. There has also been a complete lack of information that personal data has been transferred to a third country. Additionally, the supplementary information required under Chapter 8, Section 6 of the PDL is missing.

By not informing those seeking care at the time of collecting personal data during phone calls to 1177, beyond a voicemail message that the call is recorded for patient safety and quality purposes, IMY concludes that MedHelp has processed personal data in violation of Article 13 and the specified requirement for information to data subjects as stated in Chapter 8, Section 6 of the PDL.

According to Article 5.1 a of the GDPR, personal data must be processed lawfully, fairly, and transparently in relation to the data subject. The lack of information according to Article 13 is assessed, as it significantly limits the ability of those seeking care to exercise their rights, to be so extensive and serious that the deficiency is deemed to violate the principle of transparency in Article 5.1 a.

****Swedish Data Protection Authority****

Diarienummer: DI-2019-3375

17(23)

Datum: 2021-06-07

****Responsibility for Backup****

MedHelp states, among other things, the following in the supervision case. The recording of calls to 1177 answered by MedHelp's nurses occurs within MedHelp's own telephony platform. The calls are recorded and then stored on a storage server. There is no backup of the audio files. MedHelp has a special solution that is supposed to last for many years without a backup. The files are located on several disks in a RAID system. This has always been the setup for MedHelp's calls. Recorded calls can be played back by staff in MedHelp's patient safety center. In the system, a hit list can be generated, and by clicking on a row, one can proceed to the journal entry and play back the call.

****IMY's Assessment****

According to Article 32.1 of the General Data Protection Regulation (GDPR), the data controller is obliged to implement appropriate technical and organizational security measures. According to Article 32.2, when assessing the appropriate level of security, particular consideration shall be given to the risks posed by the processing, in particular from accidental or unlawful destruction, loss, or alteration, or from unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed. The ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident is, according to Article 32.1 c, a measure that may be appropriate in ensuring a level of security that is suitable in relation to the risk.

MedHelp processes personal data about care seekers in audio files with recorded calls to 1177 within its telephony platform. This occurs in MedHelp's operations according to the Health and Medical Services Act (HSL) for purposes related to care documentation. The sensitive nature of the personal data, the fact that the personal data has been collected in a confidential context related to healthcare advice, the extent of the processing, and the high risks involved impose high demands on the security measures that MedHelp must take according to Article 32.1 of the GDPR.

HSLF-FS 2016:40 contains explicit provisions regarding backup. A healthcare provider must, according to Chapter 3, Section 12 of HSLF-FS 2016:40, ensure that personal data processed in information systems is backed up with a defined periodicity and that the backups are stored securely, well-separated from the original data. The healthcare provider must also decide how long the backups should be retained and how often recovery tests of the backups should be conducted, Chapter 3, Section 13 of HSLF-FS 2016:40. The National Board of Health and Welfare's regulations constitute national law that complements and specifies the GDPR and impose an explicit requirement for backup. IMY notes that backup is a security measure that MedHelp must take to meet the requirements under Article 32.1 of the GDPR.

MedHelp's use of a robust storage medium, such as a RAID system, does not constitute backup. A RAID system does not provide protection that ensures that the data can be restored if an incident occurs that affects the accuracy of the stored data, for example, if the system is affected by malicious code. However, the fact that MedHelp uses a RAID system is significant for MedHelp's ability to maintain continuity in processing, i.e., to continuously ensure confidentiality, integrity, availability, and resilience of the processing systems and services in the manner indicated in Article 32.1 b of the GDPR.

Both measures taken to ensure continuity in daily operations, for example, by using a RAID system, and measures taken to be able to return to normal operations after an incident, such as backup, are measures...

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

18(23)

Date: 2021-06-07

to ensure accessibility. However, this does not mean that these measures can replace each other, but rather that they complement each other.

IMY notes that MedHelp, by failing to back up audio files with recorded calls to 1177 within MedHelp's telephony platform, has processed personal data in violation of Article 32.1.

According to the fundamental security principle in Article 5.1 f of the General Data Protection Regulation, personal data must be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against loss, destruction, or damage due to accidental events, using appropriate technical or organizational measures. Loss of care documentation can pose a high risk to the rights and freedoms of the care seekers. The failure to implement backup is therefore assessed to be of such a serious nature that the deficiency also constitutes a violation of Article 5.1 f of the General Data Protection Regulation.

Choice of Intervention

Possible Intervention Measures

IMY has a number of corrective powers available under Article 58.2 of the General Data Protection Regulation, including the ability to order the data controller to ensure that processing is carried out in accordance with the regulation and, if necessary, in a specific manner and within a specific period. According to Articles 58.2 and 83.2 of the General Data Protection Regulation, IMY has the authority to impose administrative fines in accordance with Article 83. Depending on the circumstances of the individual case, administrative fines may be imposed in addition to or instead of the other measures referred to in Article 58.2. Furthermore, Article 83.2 specifies the factors to be considered when deciding whether to impose administrative fines and when determining the amount of the fine. If it concerns a minor infringement, IMY may, as stated in Recital 148 of the General Data Protection Regulation, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b of the General Data Protection Regulation. Consideration should be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the infringement, as well as previous relevant infringements.

Fine to be Imposed

IMY has assessed above that MedHelp has violated Articles 5.1 a and f, 6, 9, 13, and 32.1 of the General Data Protection Regulation. Violations of these articles may, according to Articles 83.4 and 83.5, lead to administrative fines.

In light of the fact that the identified violations have concerned a very large number of care seekers who were referred to call 1177 for medical advice and have involved deficiencies in the handling of sensitive personal data such as health information, these are not minor infringements.

There is therefore no reason to replace the fine with a reprimand regarding any of these violations. MedHelp shall therefore be imposed administrative fines.

Swedish Authority for Privacy Protection

Case Number: DI-2019-3375

Page 19(23)

Date: 2021-06-07

Determination of the Amount of the Administrative Fine

General Provisions

According to Article 83.1 of the General Data Protection Regulation, each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. Article 83.2 specifies the factors to be taken into account when determining the amount of the fine concerning the infringement. In assessing the amount of the fine, consideration shall be given to, among other things, the nature, gravity, and duration of the infringement, whether it was intentional or negligent, what measures have been taken to mitigate the damage suffered by the data subjects, the degree of responsibility taking into account the technical and organizational measures implemented in accordance with Articles 25 and 32, how the supervisory subject has cooperated with the supervisory authority, what categories of personal data are affected, how the infringement came to the attention of the Swedish Authority for Privacy Protection (IMY), and whether there are any other aggravating or mitigating factors, such as direct or indirect economic benefit from the conduct.

Infringements of Articles 5.1 a and f, 6, 9, and 13 of the General Data Protection Regulation are subject to the higher administrative fine according to Article 83.5. The fine shall therefore be set at up to 20,000,000 EUR or, in the case of an undertaking, up to four percent of the total global annual turnover in the preceding financial year, whichever is higher for infringements concerning these articles. Infringements of Article 32.1 are subject to the lower administrative fine according to Article 83.4. The fine shall thus be set at up to 10,000,000 EUR or, in the case of an undertaking, up to two percent of the total global annual turnover in the preceding financial year, whichever is higher for the infringement concerning this article.

The term "an undertaking" encompasses all entities engaged in economic activity, regardless of the legal status of the entity or the manner in which it is financed.

Recital 150 of the General Data Protection Regulation states, among other things, that if administrative fines are imposed on an undertaking, an undertaking should be considered as an undertaking in the sense referred to in Articles 101 and 102 of the Treaty on the Functioning of the European Union (TFEU). This means that the assessment of what constitutes an undertaking should be based on the definitions in competition law. The rules for group liability in EU competition law revolve around the concept of an economic unit. A parent company and a subsidiary are considered part of the same economic unit when the parent company exerts decisive influence over the subsidiary. The decisive influence (i.e., control) can be achieved either through ownership or through agreement.

From MedHelp AB's annual report, it is evident that MedHelp AB is part of a group, where MedHelp AB is owned 95 percent by MedHelp Group OY (a Finnish limited company) and 5 percent by Meddet AB.

IMY believes that the fact that MedHelp is 95 percent owned by MedHelp Group OY means that the relevant group should be considered an economic unit as referred to in competition law. According to the group's annual report, the annual turnover was 223,013,000 SEK for the financial year 2019.

5 Four percent of the turnover corresponds to 8,920,000 SEK and two percent to 4,460,000 SEK.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

20(23)

Date: 2021-06-07

The maximum amount for administrative fines for violations covered by Article 83.5 of the General Data Protection Regulation is thus 20 million euros, and for violations covered by Article 83.4, 10 million euros.

Administrative fine for each violation

The Swedish Authority for Privacy Protection (IMY) has identified four violations concerning MedHelp's processing of personal data as the data controller.

MedHelp has exposed personal data in the form of audio files containing recorded telephone calls to 1177 on the internet without protection against unauthorized disclosure or unauthorized access to the personal data, in violation of Article 5.1(f) and Article 32.1 of the General Data Protection Regulation. MedHelp has processed personal data by disclosing sensitive personal data to MediCall and allowing MediCall to collect personal data in violation of Article 5.1(a), 6, and 9.1 of the General Data Protection Regulation. MedHelp has not provided information to individuals seeking care who called 1177, in violation of Article 5.1(a) and Article 13 of the General Data Protection Regulation. Finally, MedHelp has not backed up care documentation in the form of audio files containing recorded calls to 1177 that were answered by MedHelp's nurses within MedHelp's telephone platform, in violation of Article 5.1(f) and Article 32.1 of the General Data Protection Regulation.

IMY assesses that the four violations do not constitute interconnected processing and that therefore a separate administrative fine should be imposed for each violation.

For administrative fines to be effective and deterrent, the turnover of the data controller must be particularly considered when determining the size of the fines. A proportionality assessment must also be made in each individual case. In the proportionality assessment, the total administrative fine must not be too high in relation to the relevant violations and must not be too high in relation to the entity that is required to pay the fine.

The administrative fine for each violation is determined as follows:

a) Processing of personal data concerning individuals seeking care performed by MediCall

MedHelp receives approximately 3 million calls per year within the framework of 1177, of which MediCall has answered 20 percent. This amounts to about 600,000 calls per year that MediCall has answered. It is aggravating that this involves extensive processing of sensitive and privacy-sensitive personal data, that the data processing has been carried out by an organization that is not subject to the privacy-protective regulations applicable within the Swedish healthcare system, e.g., the regulation on confidentiality, that individuals seeking care have not been aware that the data processing has

taken place in Thailand, and that individuals seeking care have not been able to opt out of the relevant data processing.

In light of the seriousness of the violations and that the administrative fine must be effective, proportionate, and deterrent, IMY determines the administrative fine to be 3 million kronor for this violation.

b) Exposed audio files on the storage server Voice NAS

MedHelp has stored recordings of individuals seeking care's calls to 1177 on the storage server Voice NAS. The investigation shows that on February 18, 2019, there were 2.7 million...

6 Compare with Articles 83.4 and 83.5 of the General Data Protection Regulation.

Swedish Authority for Privacy Protection

Diary Number: DI-2019-3375

21(23)

Date: 2021-06-07

files on Voice NAS and that a call corresponds on average to about three to four files. IMY has, against this background, estimated that it involves between 650,000 and 900,000 calls.

Everyone who is ill has the right to receive care. Care seekers who are not acutely ill are referred to call 1177. This involves a trusting contact with the healthcare system where care seekers are considered to have a high expectation that unauthorized persons will not gain access to information conveyed during the call. The caller cannot oppose the processing of personal data for purposes related to healthcare documentation.

In light of the nature of the data and the high security requirements for personal data concerning care seekers, it is an aggravating circumstance that MedHelp, as a healthcare provider and data controller, has lacked control over the security of the personal data. MedHelp was unaware that the personal data in Voice NAS had become accessible without protective mechanisms. The stored content was made available online for unknown reasons to MedHelp. MedHelp became aware of the incident from the Deputy CEO of Inera AB. MedHelp acted only after the incident by investigating Voice NAS, transferring the healthcare documentation to its own servers, and informing Voice about the deletion of the calls. It is serious that a large amount of health data has been accessible to anyone with an internet connection for an unknown period.

In light of the seriousness of the violations and that the administrative fine must be effective, proportionate, and deterrent, IMY determines the administrative fine to be 8 million kronor for this violation.

c) Information to Care Seekers

MedHelp receives approximately 3 million calls per year within the framework of 1177. The provisions regarding information mean that MedHelp must proactively make care-seeking individuals aware of MedHelp's processing of personal data and their rights in connection with MedHelp's processing of personal data. This involves a comprehensive obligation to provide information, which is the basis for individuals to have knowledge of and control over how their personal data is processed.

It is aggravating that the lack of information concerns a large number of care seekers and that there is a complete absence of information that meets the requirements of the General Data Protection Regulation (GDPR) and the Data Act (PDL), except for a voicemail message stating that the call will be recorded for patient safety and quality purposes. The fact that information is not provided regarding, among other things, that MedHelp is the data controller, the purposes and legal basis for the processing, and that care seekers can contact MedHelp to exercise their rights under the GDPR significantly limits the conditions for care seekers to safeguard their rights. MedHelp has also transferred personal data about patients to MediCall, a Thai company. It is aggravating that there has been a complete lack of information regarding the transfer of personal data to Thailand, which is a third country.

In light of the seriousness of the violations and that the administrative fine must be effective,

proportionate, and deterrent, IMY determines the administrative fine to be 500,000 kronor for this violation.

d) Backup

Swedish Authority for Privacy Protection

Case Number: DI-2019-3375

22(23)

Date: 2021-06-07

MedHelp receives approximately 3 million calls per year as part of 1177. The lack of backup at MedHelp concerns a large number of healthcare seekers. It is an aggravating circumstance that there is a complete absence of backup for healthcare documentation regarding a significant number of healthcare seekers. The loss of healthcare documentation can pose a high risk to the freedoms and rights of the healthcare seekers.

In light of the seriousness of the violations and that the administrative fine must be effective, proportionate, and deterrent, IMY determines the administrative fine to be 500,000 Swedish kronor for the violation.

Summary

IMY has found that MedHelp must pay a total administrative fine of 12,000,000 Swedish kronor for the identified violations, of which 3,000,000 Swedish kronor pertains to the violation at point a), 8,000,000 Swedish kronor pertains to the violation at point b), 500,000 Swedish kronor pertains to the violation at point c), and 500,000 Swedish kronor pertains to the violation at point d).

Orders

MedHelp has not informed healthcare seekers in accordance with the requirements of the General Data Protection Regulation (GDPR) and Chapter 8, Section 6 of the PDL. The lack of information regarding, among other things, who is the data controller and their contact details limits the healthcare seeker's ability to exercise the right to request access to personal data that MedHelp collects when healthcare seekers call 1177. MedHelp has not backed up audio files that constitute healthcare documentation according to the GDPR and Chapters 3, Sections 12-13 of HSLF-FS 2016:40.

MedHelp receives approximately 3 million calls per year as part of 1177. This is a large number of healthcare seekers in need of medical advice who are affected by the deficiencies in information and backup.

MedHelp is therefore ordered under Article 58.2 d of the GDPR to ensure, as soon as possible and no later than two months after the decision has become final, that processing is conducted in accordance with the GDPR and supplementary national law regarding information to healthcare seekers and backup.

MedHelp has stated that it will suffer further harm if any orders regarding information to data subjects and backup conflict with MedHelp's agreements with Region Stockholm or with procurement law. MedHelp, as a healthcare provider and data controller, has the ultimate responsibility for lawful processing of personal data, which includes ensuring that healthcare seekers receive information about the processing of personal data and that measures for backup are taken.

This decision has been made by the Director General Lena Lindgren Schelin after presentation by IT security specialist Magnus Bergström and department director Suzanne Isberg. The unit manager Katarina Tullstedt and lawyer Mattias Sandström have participated in the processing. In the final handling, the legal manager David Törngren and unit manager Malin Blixt have also participated.

Lena Lindgren Schelin, 2021-06-07 (This is an electronic signature)

Swedish Authority for Privacy Protection

Case Number: DI-2019-3375

23(23)

Date: 2021-06-07

How to appeal

If you wish to appeal the decision, you should write to the Swedish Authority for Privacy Protection. Indicate in the letter which decision you are appealing and the amendment you are requesting. The appeal must be received by the Swedish Authority for Privacy Protection no later than three weeks from the day you received notice of the decision. If the appeal is submitted in a timely manner, the Swedish Authority for Privacy Protection will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to the Swedish Authority for Privacy Protection if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.

Appendix

Appendix – Information on payment of the sanction fee.

Copy to

MedHelp's CEO via email